



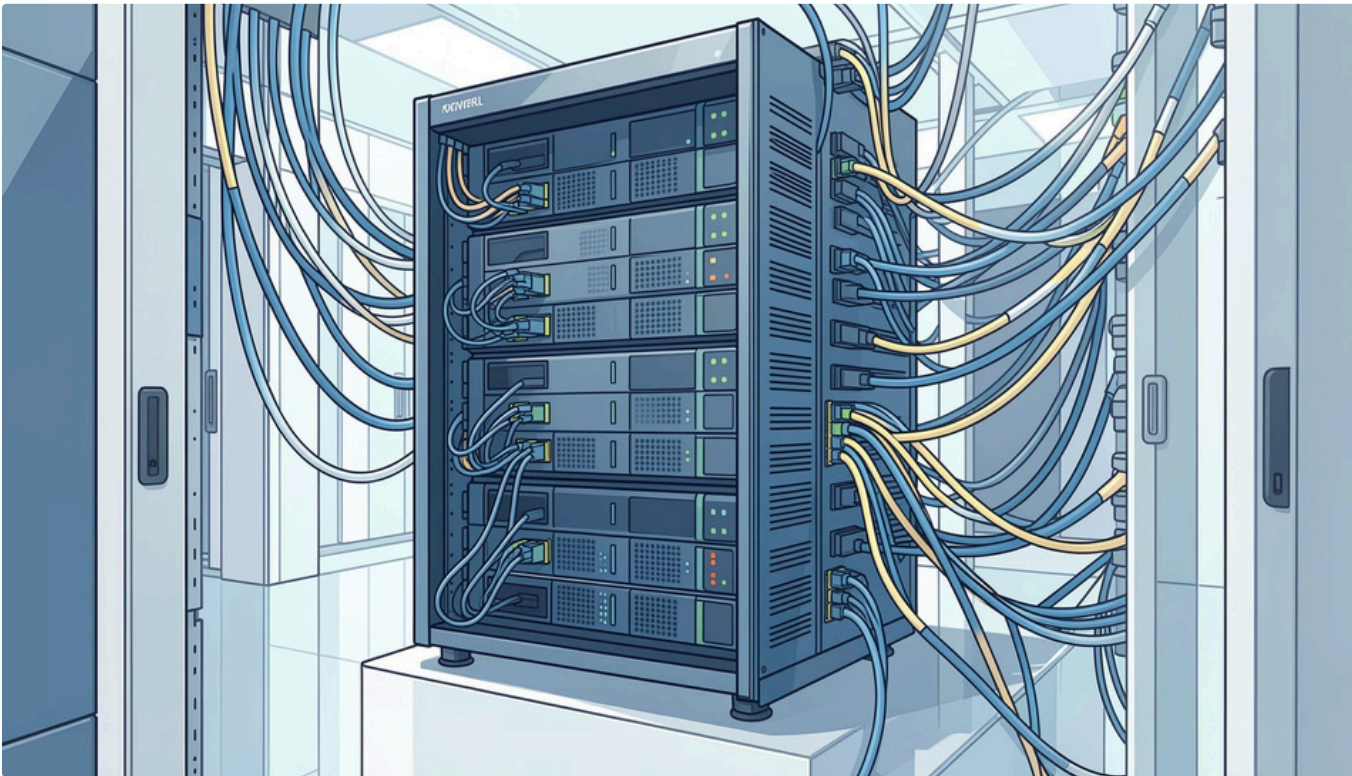
# TP Cybersécurité

Simulation d'attaque et de durcissement d'une infrastructure Windows Server / KaliLinux

YANIS BELYAMANI

JULIEN BEUGNET

# Présentation de l'infrastructure



## Windows Server

IP : 10.0.2.15

Domaine & forêt : **tp.local**

Service web IIS installé, Active Directory configuré.

## Kali Linux

Machine d'attaque utilisée pour le scan réseau, l'exploitation des vulnérabilités et les tests d'intrusion.

## Docker

Environnement conteneurisé lancé sur la machine de Julien pour isoler les services testés.

**i** Les deux machines sont placées derrière un **réseau NAT**.

# Politiques de sécurité – GPO

## Mots de passe

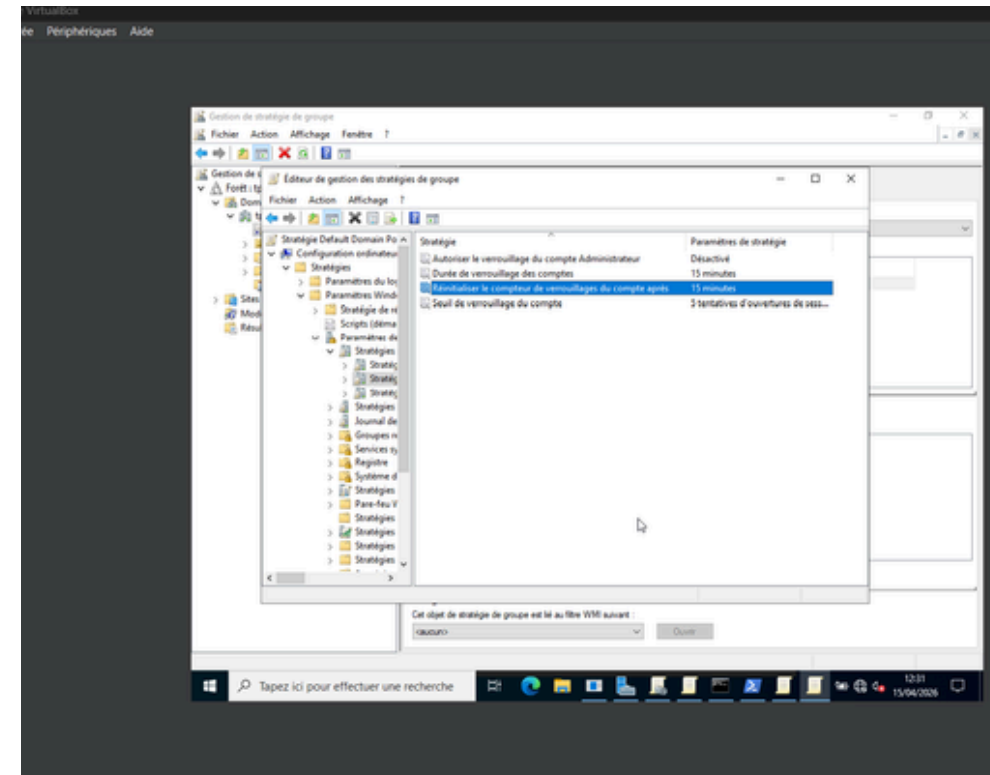
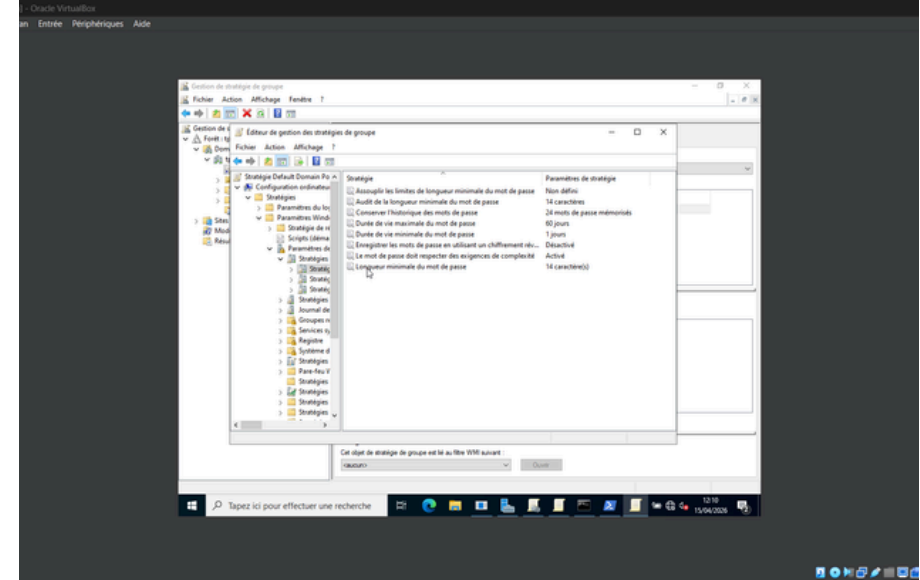
- Longueur minimale : 14 caractères
- Durée de vie : 1 à 60 jours
- Réutilisation immédiate empêchée
- Complexité imposée

## Verrouillage des comptes

- Blocage après: 5 tentatives échouées
- Durée de blocage : 15 minutes
- Compteur réinitialisé après 15 min

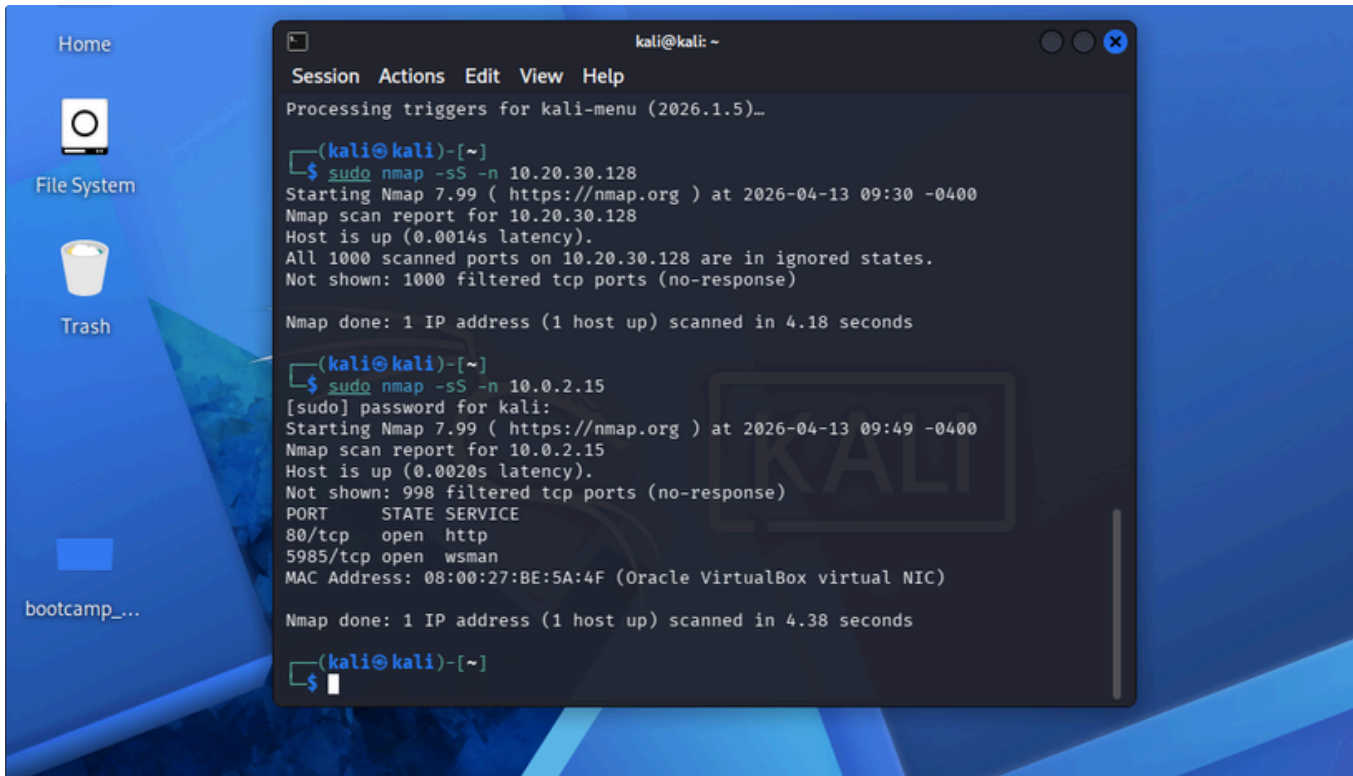
## Protocoles réseau

- SMBv1 désactivé
- NTLMv1 réduit au profit de Kerberos
- Réduction des vecteurs d'attaque connus





# Scan réseau – Résultats Nmap

A screenshot of a Kali Linux desktop environment. The desktop background is blue with a geometric pattern. On the left side, there are icons for 'Home', 'File System', 'Trash', and 'bootcamp\_...'. In the center, a terminal window is open, displaying the results of two Nmap scans. The first scan is for 10.20.30.128, showing it is up and that all 1000 scanned ports are in ignored states. The second scan is for 10.0.2.15, showing it is up and that 998 filtered tcp ports are in no-response state. The terminal window has a menu bar with 'Session', 'Actions', 'Edit', 'View', and 'Help'. The terminal output shows the Nmap version 7.99 and the scan date 2026-04-13 09:30 -0400 for the first scan, and 2026-04-13 09:49 -0400 for the second scan. The second scan results show open ports 80/tcp (http) and 5985/tcp (wsman).

```
kali@kali: ~  
Session Actions Edit View Help  
Processing triggers for kali-menu (2026.1.5)...  
  
(kali@kali)-[~]  
$ sudo nmap -sS -n 10.20.30.128  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-13 09:30 -0400  
Nmap scan report for 10.20.30.128  
Host is up (0.0014s latency).  
All 1000 scanned ports on 10.20.30.128 are in ignored states.  
Not shown: 1000 filtered tcp ports (no-response)  
  
Nmap done: 1 IP address (1 host up) scanned in 4.18 seconds  
  
(kali@kali)-[~]  
$ sudo nmap -sS -n 10.0.2.15  
[sudo] password for kali:  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-13 09:49 -0400  
Nmap scan report for 10.0.2.15  
Host is up (0.0020s latency).  
Not shown: 998 filtered tcp ports (no-response)  
PORT      STATE SERVICE  
80/tcp    open  http  
5985/tcp   open  wsman  
MAC Address: 08:00:27:BE:5A:4F (Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 4.38 seconds  
  
(kali@kali)-[~]  
$
```

## Ports ouverts détectés

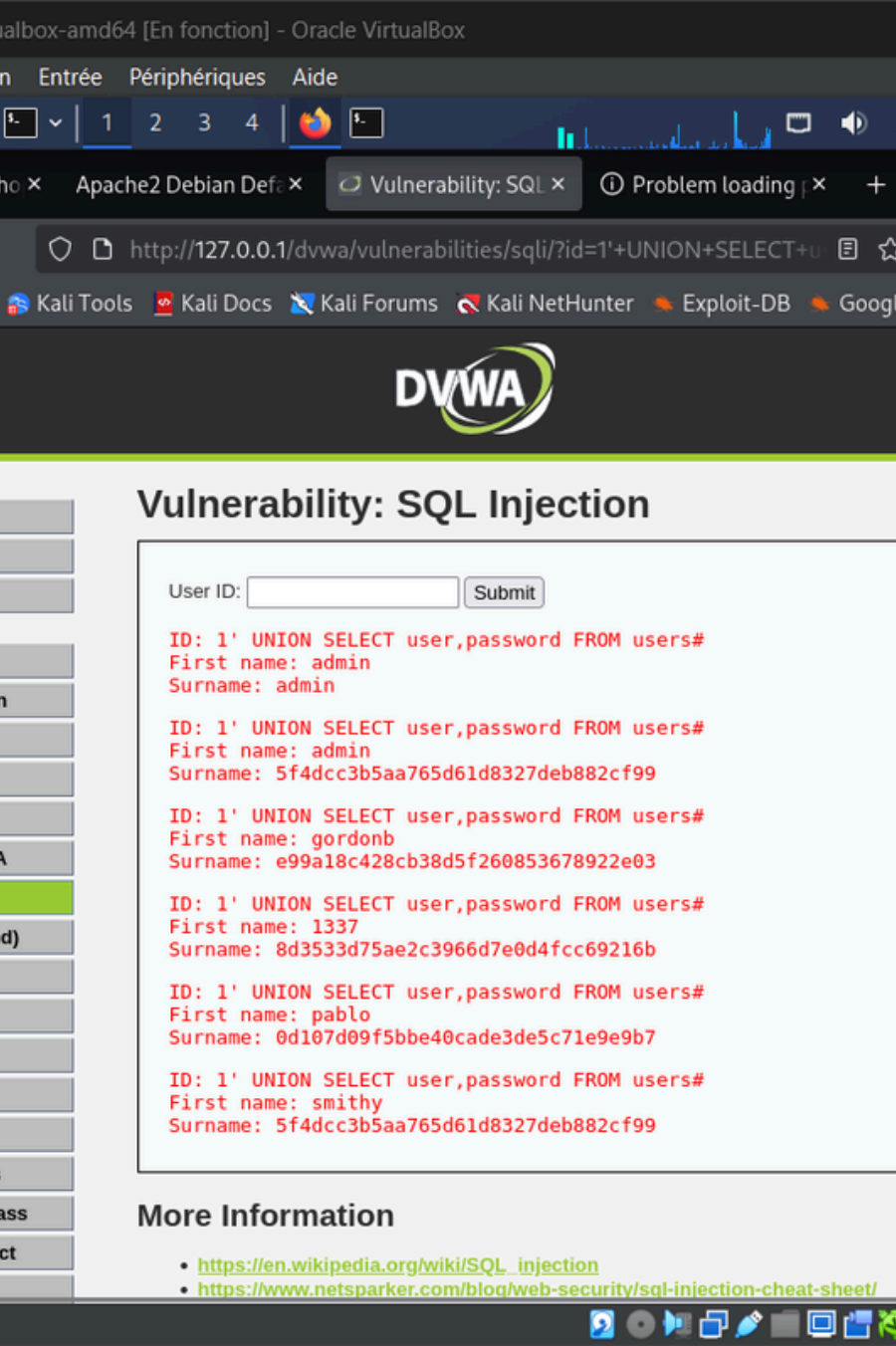
### Port 80/tcp – HTTP

Microsoft IIS 10.0—Serveur web, point d'entrée principal pour la reconnaissance.

### Port 5985/tcp – WinRM

Windows RemoteManagement—Administration distante via HTTP, critique si mal configuré.

- ❏ La majorité des autres ports sont **filtrés**, signe d'un pare-feu actif. Surface d'attaque réduite mais non négligeable.



# Vulnérabilité #1 – Injection SQL

## Payload utilisé

```
1' UNION SELECT
user,password FROM
users#
```

## Ce que ça fait

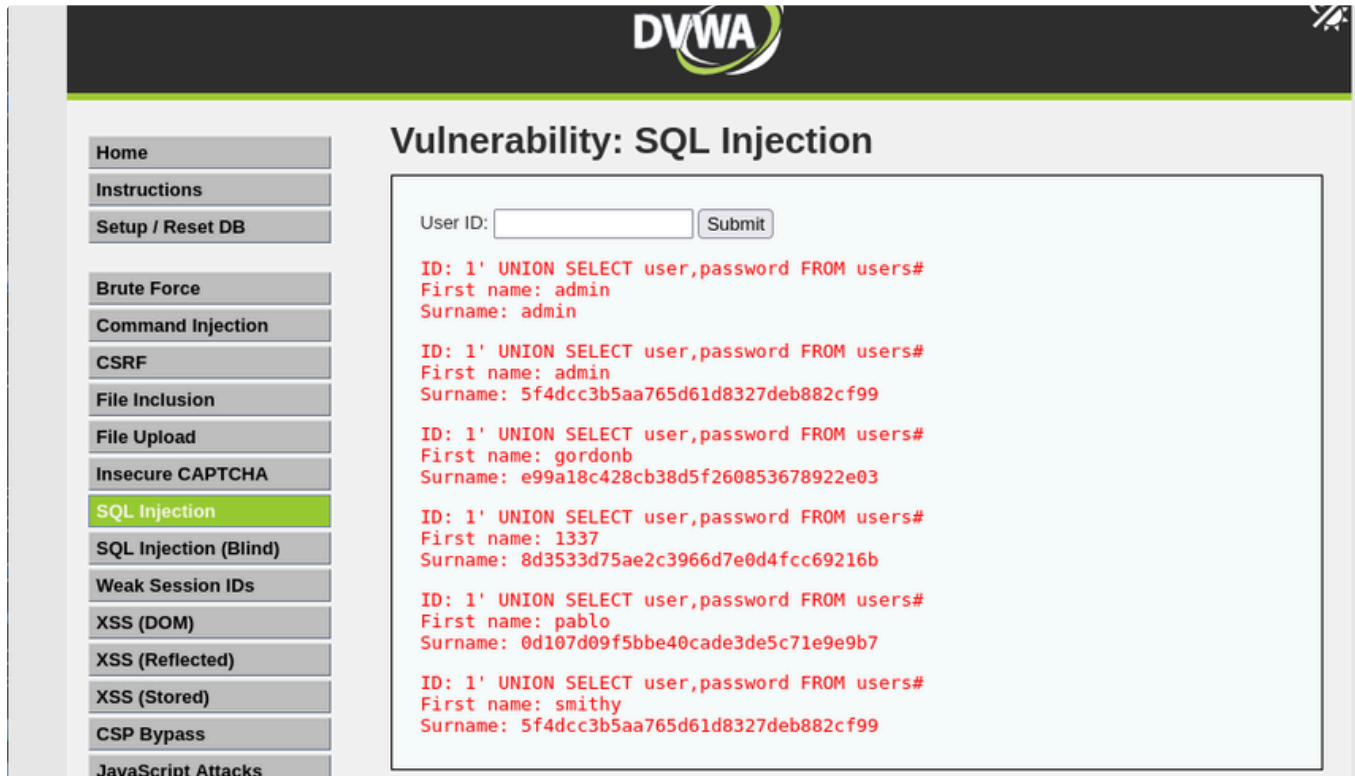
Extraction des identifiants et des mots de passe (hashés) directement depuis la base de données, **sans authentification.**

## Score CVSS v3.1

### 9.8— Critique

Accès total à la BDD, fuite d'identifiants, risque de compromission complète du système.

# Vulnérabilité #2 – XSS Réfléchi



## Payload utilisé

```
<script>alert(1);</script>
```

## Impact

Exécution de code JavaScript dans le navigateur de la victime. Permet de :

Voler des **cookies de session**

Rediriger vers un site **malveillant**

Injecter du contenu **frauduleux**

- 



**CVSS : 6.1 — Moyen — Risque**  
réel en contexte utilisateur.

# Correction des vulnérabilités

## Injection SQL — Requêtes préparées

Remplacement de la concaténation directe par des **requêtes préparées** **mysqli**. La structure de la requête est séparée des données utilisateur, empêchant toute modification malveillante.

## XSS — htmlspecialchars()

Ajout de la fonction **htmlspecialchars()** pour échapper les caractères spéciaux. Les balises `<script>` sont rendues inoffensives à l'affichage.

## Headers de sécurité HTTP

Ajout d'en-têtes pour bloquer le **clickjacking** (iframe), renforcer la protection XSS et éviter les mauvaises interprétations du contenu par le navigateur.

```
$result = mysqli_stmt_get_result($stmt);
```

Partie : XSS

```
dwwaMessagePush(
```

```
    "You have logged in as '" .
```

```
    htmlspecialchars($user, ENT_QUOTES, 'UTF-8') .
```

```
    ""
```

```
);
```

Partie : Headers de sécurité

Les en-têtes suivants ont été ajoutés :

```
Header('X-Frame-Options: DENY');
```

```
Header('X-Content-Type-Options: nosniff');
```

```
Header('X-XSS-Protection: 1; mode=block');
```

Explications



# Hardening – Sécurisation du système



## SSH sécurisé

Port changé de 22 → 2222, connexion root désactivée, authentification par clé SSH uniquement.



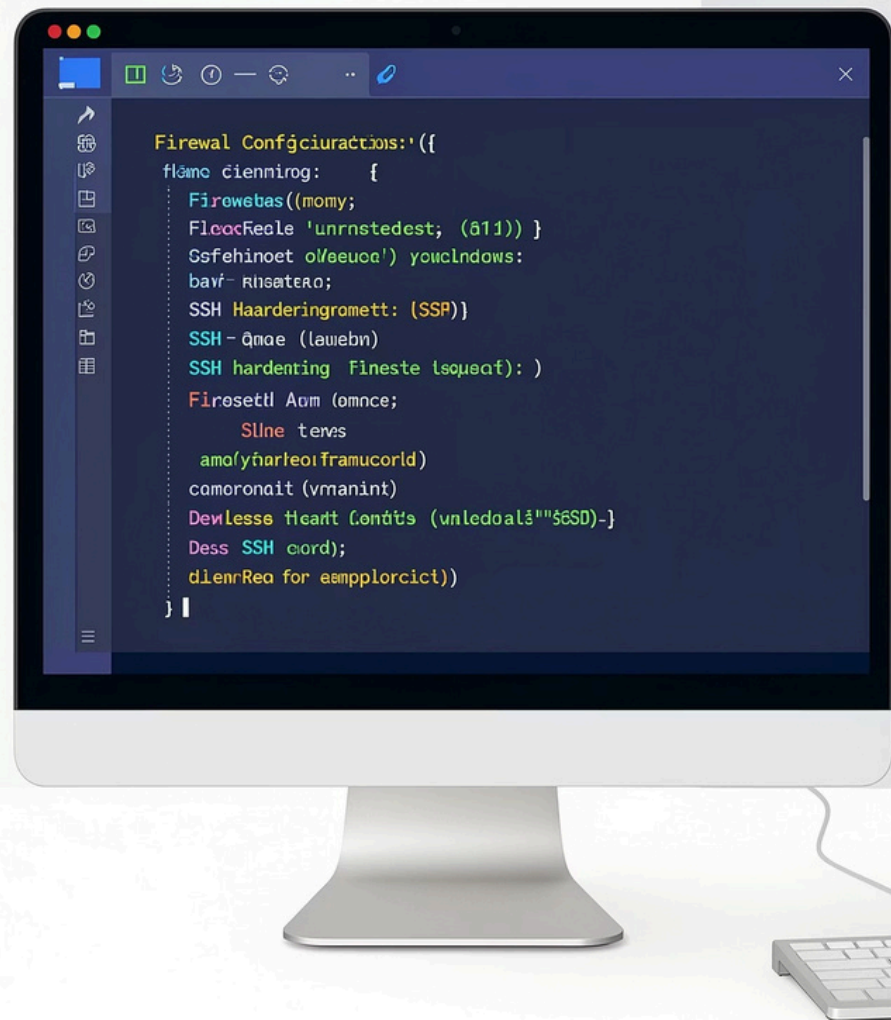
## Pare-feu UFW configuré

Seuls les ports 2222 (SSH) et 80 (HTTP) sont autorisés. Tous les autres sont bloqués par défaut.

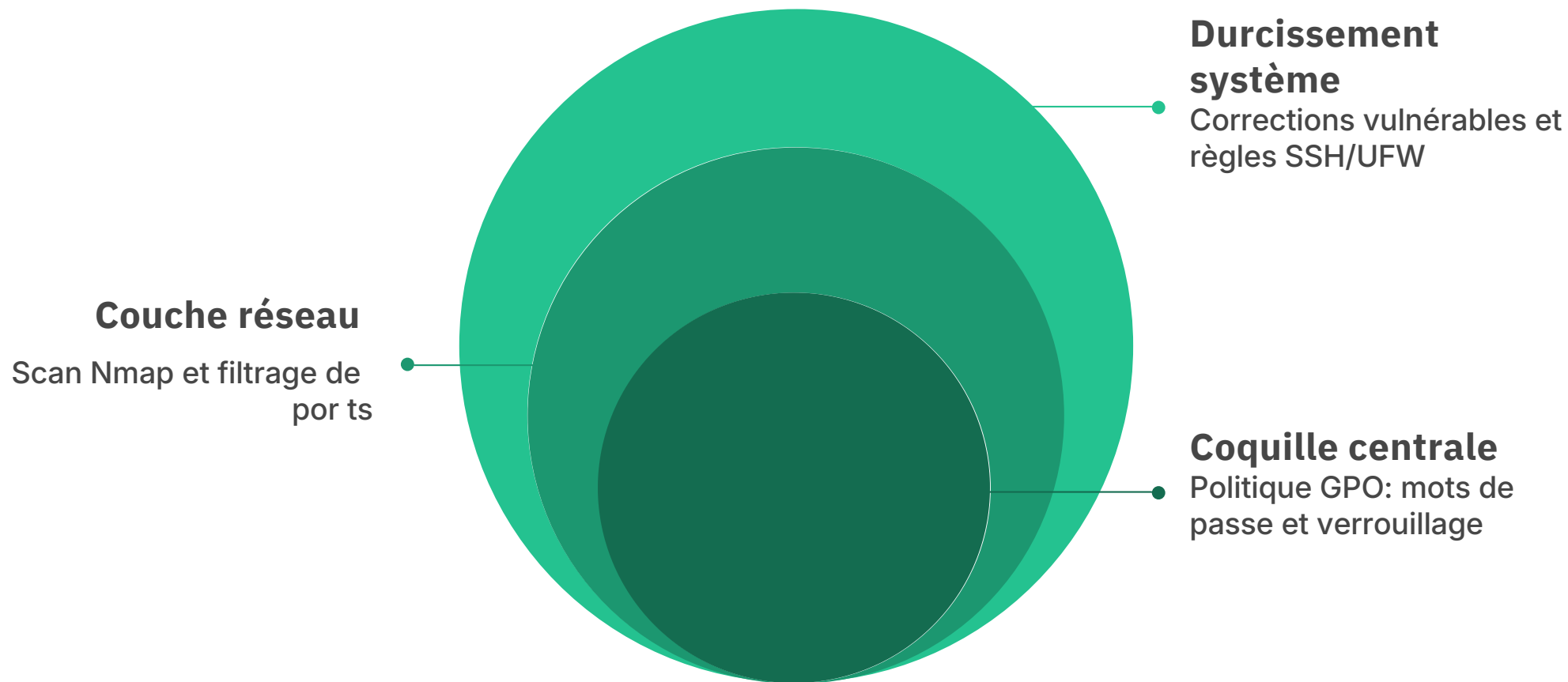


## Permissions des fichiers

Audit réalisé avec `find/-perm777 -typef`. **Aucun fichier** aux permissions excessives détecté.



# Récapitulatif des mesures de sécurité



Une approche en **quatre couches** complémentaires pour réduire la surface d'attaque et renforcer la résilience de l'infrastructure.



# Conclusion

## → Infrastructure durcie

GPO, désactivation de protocoles obsolètes et firewall réduisent significativement les risques.

## → Vulnérabilités identifiées et corrigées

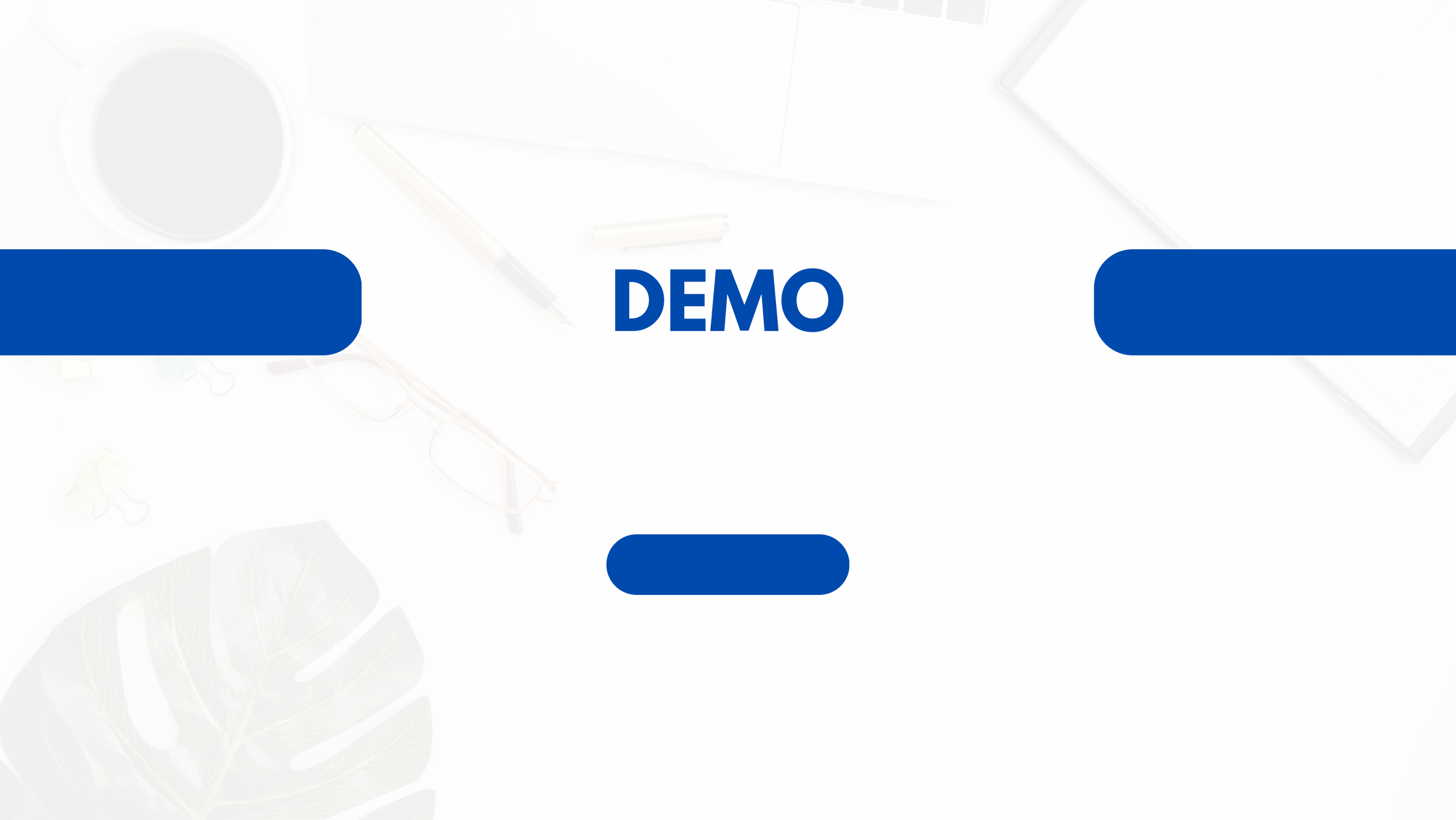
Injection SQL (CVSS9.8) et XSS réfléchi (CVSS6.1) analysés, exploités puis corrigés dans le code.

## → Vigilance continue

Surveillance des logs, mises à jour régulières et audit des permissions restent indispensables.

YANIS BELYAMANI

JULIEN BEUGNET



**DEMO**